

# AWS Well Architected Framework Review Report

|              |                                                                                                                                           |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| WAFPillar    | Security                                                                                                                                  |
| Question     | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| BestPractice | Train for application security                                                                                                            |
| Severity     | Medium                                                                                                                                    |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| Validation   | Application security training                                                                                                             |
| Status       | Requires manual review - verify security training program exists                                                                          |

|              |                                                                                                                                           |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| WAFPillar    | Security                                                                                                                                  |
| Question     | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| BestPractice | Automate testing throughout the development and release lifecycle                                                                         |
| Severity     | Medium                                                                                                                                    |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| Validation   | CI/CD pipelines for automated testing                                                                                                     |
| Status       | No CI/CD pipelines found                                                                                                                  |

|              |                                                                                                                                           |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| WAFPillar    | Security                                                                                                                                  |
| Question     | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| BestPractice | Perform regular penetration testing                                                                                                       |
| Severity     | High                                                                                                                                      |

|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>Reference</b>  | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b> | Penetration testing schedule                                  |
| <b>Status</b>     | Requires manual review - verify regular penetration testing   |

|                      |                                                                                                                                           |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAF Pillar</b>    | Security                                                                                                                                  |
| <b>Question</b>      | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| <b>Best Practice</b> | Manual code reviews                                                                                                                       |
| <b>Severity</b>      | Medium                                                                                                                                    |
| <b>Reference</b>     | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| <b>Validation</b>    | Code review process                                                                                                                       |
| <b>Status</b>        | Requires manual review - verify code review process exists                                                                                |

|                      |                                                                                                                                           |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAF Pillar</b>    | Security                                                                                                                                  |
| <b>Question</b>      | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| <b>Best Practice</b> | Centralize services for packages and dependencies                                                                                         |
| <b>Severity</b>      | Medium                                                                                                                                    |
| <b>Reference</b>     | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| <b>Validation</b>    | Centralized package management (CodeArtifact)                                                                                             |
| <b>Status</b>        | No centralized package management detected                                                                                                |

|                   |                                                                                                                                           |
|-------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAF Pillar</b> | Security                                                                                                                                  |
| <b>Question</b>   | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |

|                     |                                                                 |
|---------------------|-----------------------------------------------------------------|
| <b>BestPractice</b> | Deploy software programmatically                                |
| <b>Severity</b>     | High                                                            |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>   |
| <b>Validation</b>   | Programmatic deployment (CodeDeploy/CodePipeline)               |
| <b>Status</b>       | No CodeDeploy or CodePipeline found for programmatic deployment |

|                     |                                                                                                                                           |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                                                                                                  |
| <b>Question</b>     | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| <b>BestPractice</b> | Regularly assess security properties of the pipelines                                                                                     |
| <b>Severity</b>     | High                                                                                                                                      |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| <b>Validation</b>   | Pipeline security assessment                                                                                                              |
| <b>Status</b>       | Requires manual review - verify pipeline security reviews                                                                                 |

|                     |                                                                                                                                           |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                                                                                                  |
| <b>Question</b>     | How do you incorporate and validate the security properties of applications throughout the design, development, and deployment lifecycle? |
| <b>BestPractice</b> | Build a program that embeds security ownership in workload teams                                                                          |
| <b>Severity</b>     | Low                                                                                                                                       |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                             |
| <b>Validation</b>   | Security ownership program                                                                                                                |
| <b>Status</b>       | Requires manual review - verify security champions program                                                                                |

|                     |                                                                  |
|---------------------|------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                         |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents?   |
| <b>BestPractice</b> | Identify key personnel and external resources                    |
| <b>Severity</b>     | High                                                             |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>    |
| <b>Validation</b>   | Key personnel identification                                     |
| <b>Status</b>       | Requires manual review - verify incident contacts are documented |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Develop incident management plans                              |
| <b>Severity</b>     | High                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | Incident management plans                                      |
| <b>Status</b>       | Requires manual review - verify incident response plans exist  |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Prepare forensic capabilities                                  |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | Forensic capabilities (CloudTrail)                             |
| <b>Status</b>       | CloudTrail log validation not enabled                          |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Develop and test security incident response playbooks          |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | SSM Automation documents for playbooks                         |
| <b>Status</b>       | 485 SSM Automation documents available for incident response   |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Pre-provision access                                           |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | Pre-provisioned incident/emergency roles                       |
| <b>Status</b>       | No incident/forensic/breakglass/emergency roles found          |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Pre-deploy tools                                               |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | SSM managed instances for tool deployment                      |
| <b>Status</b>       | No instances managed by SSM for tool deployment                |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Run simulations                                                |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | Incident simulation exercises                                  |
| <b>Status</b>       | Requires manual review - verify regular simulation exercises   |

|                     |                                                                |
|---------------------|----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                       |
| <b>Question</b>     | How do you anticipate, respond to, and recover from incidents? |
| <b>BestPractice</b> | Establish a framework for learning from incidents              |
| <b>Severity</b>     | Medium                                                         |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>  |
| <b>Validation</b>   | Post-incident learning framework                               |
| <b>Status</b>       | Requires manual review - verify lessons learned process exists |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your data in transit?                      |
| <b>BestPractice</b> | Implement secure key and certificate management               |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | ACM certificate management                                    |

|        |                                                |
|--------|------------------------------------------------|
| Status | 4 certificates managed in ACM, 4 expiring soon |
|--------|------------------------------------------------|

|              |                                                               |
|--------------|---------------------------------------------------------------|
| WAFPillar    | Security                                                      |
| Question     | How do you protect your data in transit?                      |
| BestPractice | Enforce encryption in transit                                 |
| Severity     | High                                                          |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| Validation   | Encryption in transit (HTTPS listeners)                       |
| Status       | 0 HTTPS listeners, 0 HTTP listeners                           |

|              |                                                                            |
|--------------|----------------------------------------------------------------------------|
| WAFPillar    | Security                                                                   |
| Question     | How do you protect your data in transit?                                   |
| BestPractice | Authenticate network communications                                        |
| Severity     | Low                                                                        |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>              |
| Validation   | VPN and network authentication                                             |
| Status       | No VPN connections found. Verify VPC peering uses encryption if applicable |

|              |                                                               |
|--------------|---------------------------------------------------------------|
| WAFPillar    | Security                                                      |
| Question     | How do you protect your data at rest?                         |
| BestPractice | Implement secure key management                               |
| Severity     | High                                                          |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |

|                   |                                              |
|-------------------|----------------------------------------------|
| <b>Validation</b> | KMS key rotation                             |
| <b>Status</b>     | 1/3 KMS keys have automatic rotation enabled |

|                     |                                                                 |
|---------------------|-----------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                        |
| <b>Question</b>     | How do you protect your data at rest?                           |
| <b>BestPractice</b> | Enforce encryption at rest                                      |
| <b>Severity</b>     | High                                                            |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>   |
| <b>Validation</b>   | EBS and S3 encryption                                           |
| <b>Status</b>       | EBS default encryption not enabled; S3: 12/12 buckets encrypted |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your data at rest?                         |
| <b>BestPractice</b> | Automate data at rest protection                              |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Config encryption rules                                       |
| <b>Status</b>       | No encryption Config rules found                              |

|                     |                                       |
|---------------------|---------------------------------------|
| <b>WAFPillar</b>    | Security                              |
| <b>Question</b>     | How do you protect your data at rest? |
| <b>BestPractice</b> | Enforce access control                |
| <b>Severity</b>     | Low                                   |



|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>Reference</b>  | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b> | S3 block public access                                        |
| <b>Status</b>     | Block public access settings not fully enabled                |

|                      |                                                                   |
|----------------------|-------------------------------------------------------------------|
| <b>WAF Pillar</b>    | Security                                                          |
| <b>Question</b>      | How do you classify your data?                                    |
| <b>Best Practice</b> | Understand your data classification scheme                        |
| <b>Severity</b>      | High                                                              |
| <b>Reference</b>     | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>     |
| <b>Validation</b>    | Data classification scheme                                        |
| <b>Status</b>        | Requires manual review - verify data classification policy exists |

|                      |                                                               |
|----------------------|---------------------------------------------------------------|
| <b>WAF Pillar</b>    | Security                                                      |
| <b>Question</b>      | How do you classify your data?                                |
| <b>Best Practice</b> | Apply data protection controls based on data sensitivity      |
| <b>Severity</b>      | High                                                          |
| <b>Reference</b>     | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>    | S3 bucket default encryption                                  |
| <b>Status</b>        | 12/12 buckets have default encryption                         |

|                      |                                            |
|----------------------|--------------------------------------------|
| <b>WAF Pillar</b>    | Security                                   |
| <b>Question</b>      | How do you classify your data?             |
| <b>Best Practice</b> | Automate identification and classification |

|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>Severity</b>   | Medium                                                        |
| <b>Reference</b>  | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b> | Macie for automated classification                            |
| <b>Status</b>     | Macie not enabled                                             |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you classify your data?                                |
| <b>BestPractice</b> | Define scalable data lifecycle management                     |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | S3 bucket lifecycle policies                                  |
| <b>Status</b>       | 5/12 buckets have lifecycle policies                          |

|                     |                                                                     |
|---------------------|---------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                            |
| <b>Question</b>     | How do you protect your compute resources?                          |
| <b>BestPractice</b> | Perform vulnerability management                                    |
| <b>Severity</b>     | High                                                                |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>       |
| <b>Validation</b>   | Vulnerability Management enabled                                    |
| <b>Status</b>       | Inspector not enabled, Config enabled, and Security Hub not enabled |

|                  |                                            |
|------------------|--------------------------------------------|
| <b>WAFPillar</b> | Security                                   |
| <b>Question</b>  | How do you protect your compute resources? |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>BestPractice</b> | Automate compute protection                                   |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Compute automation (SSM)                                      |
| <b>Status</b>       | No EC2 instances found                                        |

|                     |                                                                   |
|---------------------|-------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                          |
| <b>Question</b>     | How do you protect your compute resources?                        |
| <b>BestPractice</b> | Validate software integrity                                       |
| <b>Severity</b>     | Low                                                               |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>     |
| <b>Validation</b>   | Software integrity validation                                     |
| <b>Status</b>       | Requires manual review - verify code signing and integrity checks |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your compute resources?                    |
| <b>BestPractice</b> | Provision compute from hardened images                        |
| <b>Severity</b>     | Low                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Hardened images (custom AMIs)                                 |
| <b>Status</b>       | No custom hardened AMIs found                                 |

|                  |          |
|------------------|----------|
| <b>WAFPillar</b> | Security |
|------------------|----------|

|                     |                                                                  |
|---------------------|------------------------------------------------------------------|
| <b>Question</b>     | How do you protect your compute resources?                       |
| <b>BestPractice</b> | Reduce manual management and interactive access                  |
| <b>Severity</b>     | Medium                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>    |
| <b>Validation</b>   | Reduce manual access (SSM vs key pairs)                          |
| <b>Status</b>       | 0 instances SSM-managed, 0 with key pairs (potential SSH access) |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your network resources?                    |
| <b>BestPractice</b> | Create network layers                                         |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Availability of public and private                            |
| <b>Status</b>       | VPC has only public subnets                                   |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your network resources?                    |
| <b>BestPractice</b> | Control traffic within your network layers                    |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Availability of NACL                                          |
| <b>Status</b>       | NACL available                                                |
| <b>Data</b>         | - VPC: N/A   ID: vpc-c90146b1   NACLs: 1                      |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you protect your network resources?                    |
| <b>BestPractice</b> | Implement inspection-based protection                         |
| <b>Severity</b>     | Low                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Transit Gateway appliance mode and WAF availability           |
| <b>Status</b>       | Transit gateway inspection enabled and WAF not available      |

|                     |                                                                    |
|---------------------|--------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                           |
| <b>Question</b>     | How do you detect and investigate security events?                 |
| <b>BestPractice</b> | Configure service and application logging                          |
| <b>Severity</b>     | High                                                               |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>      |
| <b>Validation</b>   | CloudTrail and VPC Flow Logs                                       |
| <b>Status</b>       | CloudTrail: 1 trails (1 multi-region), VPC Flow Logs: 0 configured |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you detect and investigate security events?            |
| <b>BestPractice</b> | Capture logs, findings, and metrics in standardized locations |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | CloudWatch Log Groups                                         |

|        |                                  |
|--------|----------------------------------|
| Status | 10 log groups in CloudWatch Logs |
|--------|----------------------------------|

|              |                                                               |
|--------------|---------------------------------------------------------------|
| WAFPillar    | Security                                                      |
| Question     | How do you detect and investigate security events?            |
| BestPractice | Correlate and enrich security alerts                          |
| Severity     | Low                                                           |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| Validation   | Security Hub alert correlation                                |
| Status       | Security Hub not enabled                                      |

|              |                                                               |
|--------------|---------------------------------------------------------------|
| WAFPillar    | Security                                                      |
| Question     | How do you detect and investigate security events?            |
| BestPractice | Initiate remediation for non-compliant resources              |
| Severity     | Medium                                                        |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| Validation   | Config rules with remediation                                 |
| Status       | 0/3 Config rules have remediation                             |

|              |                                                               |
|--------------|---------------------------------------------------------------|
| WAFPillar    | Security                                                      |
| Question     | How do you manage permissions for people and machines?        |
| BestPractice | Define access requirements                                    |
| Severity     | High                                                          |
| Reference    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |

|                   |                                   |
|-------------------|-----------------------------------|
| <b>Validation</b> | Access requirements documentation |
| <b>Status</b>     | Requires manual review            |

|                     |                                                                                                                                                                                                                                                                                               |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                                                                                                                                                                                                                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?                                                                                                                                                                                                                                        |
| <b>BestPractice</b> | Grant least privilege access                                                                                                                                                                                                                                                                  |
| <b>Severity</b>     | High                                                                                                                                                                                                                                                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                                                                                                                                                                                 |
| <b>Validation</b>   | Wildcard permissions in attached local policies                                                                                                                                                                                                                                               |
| <b>Status</b>       | 7 policies with wildcard permissions detected                                                                                                                                                                                                                                                 |
| <b>Policies</b>     | <ul style="list-style-type: none"> <li>- deployments_s3_access</li> <li>- inventory_collector_policy</li> <li>- qualys_custom_policy</li> <li>- AWSQuickSightIAMPolicy</li> <li>- curreaderpolicy</li> <li>- island-dlp-security-artifacts-policy</li> <li>- AWSQuickSightS3Policy</li> </ul> |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Establish emergency access process                            |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Emergency access roles                                        |
| <b>Status</b>       | No emergency access roles detected                            |

|                  |          |
|------------------|----------|
| <b>WAFPillar</b> | Security |
|------------------|----------|

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Reduce permissions continuously                               |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | IAM Access Analyzer                                           |
| <b>Status</b>       | IAM Access Analyzer enabled                                   |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Define permission guardrails for your organization            |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Service Control Policies                                      |
| <b>Status</b>       | 3 SCP(s) defined                                              |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Manage access based on lifecycle                              |
| <b>Severity</b>     | Low                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Lifecycle-based access management                             |
| <b>Status</b>       | Requires manual review                                        |



|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Analyze public and cross account access                       |
| <b>Severity</b>     | Low                                                           |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | External access findings                                      |
| <b>Status</b>       | 8424 external access finding(s) identified                    |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Share resources securely within your organization             |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Resource shares within organization                           |
| <b>Status</b>       | 0 resource share(s) (RAM)                                     |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage permissions for people and machines?        |
| <b>BestPractice</b> | Share resources securely with a third party                   |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Cross-account principals in policies                          |
| <b>Status</b>       | No cross-account principals found in local policies           |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage identities for people and machines?         |
| <b>BestPractice</b> | Use strong sign-in mechanisms                                 |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Strong Password Policy                                        |
| <b>Status</b>       | Enforced                                                      |

|                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>      | Security                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Question</b>       | How do you manage identities for people and machines?                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>BestPractice</b>   | Use temporary credentials                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>Severity</b>       | High                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>Reference</b>      | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>Validation</b>     | Total roles, total assumable roles count and inactive roles                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Status</b>         | <b>Total Roles 52 Assumable roles 52 Inactive roles 19</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Inactive roles</b> | <ul style="list-style-type: none"> <li>- aws-quicksight-service-role-v0 is inactive for more than 90 days</li> <li>- AWSArtifactAccountSync is inactive for more than 90 days</li> <li>- AWSServiceRoleForAmazonInspector is inactive for more than 90 days</li> <li>- AWSServiceRoleForAmazonMacie is inactive for more than 90 days</li> <li>- AWSServiceRoleForAWSServiceCatalogAppRegistry is inactive for more than 90 days</li> <li>- AWSServiceRoleForCloudFormationStackSetsOrgAdmin is inactive for more than 90 days</li> <li>- AWSServiceRoleForElasticLoadBalancing is inactive for more than 90 days</li> <li>- AWSServiceRoleForSecurityHub is inactive for more than 90 days</li> <li>- AWSServiceRoleForServiceQuotas is inactive for more than 90 days</li> <li>- cloudcraft_RO is inactive for more than 90 days</li> <li>- cloudzero-connected-account-NotificationFunctionRole-YtSCL8gCqcyR is inactive for more than 90 days</li> <li>- cloudzero-connected-account--CostAndUsageReportRole-l0zTD9W7u28Q is inactive for more than 90 days</li> <li>- cloudzero-connected-account-AuditAccount-JUO74-Role-W2wbUeJxrgc0 is inactive for more than 90 days</li> <li>- cloudzero-connected-account-D-DiscoveryFunctionRole-QQtJjsQ8vJIB is inactive for more than 90 days</li> <li>- inventory_collector_role is inactive for more than 90 days</li> </ul> |

|  |                                                                                                                                                                                                                                                                                                                       |
|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <ul style="list-style-type: none"> <li>- Master-AWS-Billing is inactive for more than 90 days</li> <li>- Master_Admins is inactive for more than 90 days</li> <li>- Root-ReadOnly is inactive for more than 90 days</li> <li>- sumologic-events-s3-SumoRole-yRqVDbuxcFta is inactive for more than 90 days</li> </ul> |
|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you manage identities for people and machines?         |
| <b>BestPractice</b> | Store and use secrets securely                                |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Passwords stored securely                                     |
| <b>Status</b>       | No Passwords stored in Services Systems Manager               |

|                     |                                                                                                                                                                    |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                                                                                                                           |
| <b>Question</b>     | How do you manage identities for people and machines?                                                                                                              |
| <b>BestPractice</b> | Rely on a centralized identity provider                                                                                                                            |
| <b>Severity</b>     | High                                                                                                                                                               |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                                                      |
| <b>Validation</b>   | Active Users                                                                                                                                                       |
| <b>Status</b>       | Non-federated identities are available                                                                                                                             |
| <b>Data</b>         | <ul style="list-style-type: none"> <li>- certifydnsadmin_root</li> <li>- deployments</li> <li>- PROD-Root-Admin_TempUser</li> <li>- svcp_trunas_archive</li> </ul> |

|                  |          |
|------------------|----------|
| <b>WAFPillar</b> | Security |
|------------------|----------|

|                         |                                                                                                                        |
|-------------------------|------------------------------------------------------------------------------------------------------------------------|
| <b>Question</b>         | How do you manage identities for people and machines?                                                                  |
| <b>BestPractice</b>     | Audit and rotate credentials periodically                                                                              |
| <b>Severity</b>         | High                                                                                                                   |
| <b>Reference</b>        | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                          |
| <b>Validation</b>       | Users with access key's age is beyond 90 days and<br>Users with Administrator access                                   |
| <b>Status</b>           | Not Enforced                                                                                                           |
| <b>Aged Access Keys</b> | <ul style="list-style-type: none"> <li>- certifydnsadmin_root</li> <li>- deployments</li> <li>- deployments</li> </ul> |

|                     |                                                                                                                                                                                                        |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                                                                                                                                                               |
| <b>Question</b>     | How do you manage identities for people and machines?                                                                                                                                                  |
| <b>BestPractice</b> | Employ user groups and attributes                                                                                                                                                                      |
| <b>Severity</b>     | Low                                                                                                                                                                                                    |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>                                                                                                                                          |
| <b>Validation</b>   | Groups with administrator access                                                                                                                                                                       |
| <b>Groups</b>       | - {'Path': '/', 'GroupName': 'Admins', 'GroupId': 'AGPAITYNQKKR3LA2RS4D4', 'Arn': 'arn:aws:iam::595588732539:group/Admins', 'CreateDate': datetime.datetime(2017, 12, 12, 20, 37, 57, tzinfo=tzutc())} |
| <b>Status</b>       | Groups with administrator privilege are available                                                                                                                                                      |

|                     |                                           |
|---------------------|-------------------------------------------|
| <b>WAFPillar</b>    | Security                                  |
| <b>Question</b>     | How do you securely operate your workload |
| <b>BestPractice</b> | Separate workloads using accounts         |
| <b>Severity</b>     | High                                      |

|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>Reference</b>  | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b> | Account separation                                            |
| <b>Status</b>     | Workloads separated across 12 accounts                        |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you securely operate your workload                     |
| <b>BestPractice</b> | Secure account root user and properties                       |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Root user MFA and access keys                                 |
| <b>Status</b>       | Root user secured with MFA, no access keys                    |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you securely operate your workload                     |
| <b>BestPractice</b> | Identify and validate control objectives                      |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Control objectives identification                             |
| <b>Status</b>       | Requires manual review - verify documented control objectives |

|                     |                                                                  |
|---------------------|------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                         |
| <b>Question</b>     | How do you securely operate your workload                        |
| <b>BestPractice</b> | Identify threats and prioritize mitigations using a threat model |

|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>Severity</b>   | High                                                          |
| <b>Reference</b>  | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b> | Threat model documentation                                    |
| <b>Status</b>     | Requires manual review - verify threat model exists           |

|                     |                                                                     |
|---------------------|---------------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                            |
| <b>Question</b>     | How do you securely operate your workload                           |
| <b>BestPractice</b> | Evaluate and implement new security services and features regularly |
| <b>Severity</b>     | Low                                                                 |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a>       |
| <b>Validation</b>   | Security services enabled (GuardDuty, Security Hub)                 |
| <b>Status</b>       | us-east-1: GuardDuty=enabled, Security Hub=not enabled              |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you securely operate your workload                     |
| <b>BestPractice</b> | Reduce security management scope                              |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Service Control Policies                                      |
| <b>Status</b>       | 3 SCP(s) defined                                              |

|                  |                                           |
|------------------|-------------------------------------------|
| <b>WAFPillar</b> | Security                                  |
| <b>Question</b>  | How do you securely operate your workload |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>BestPractice</b> | Automate deployment of standard security controls             |
| <b>Severity</b>     | Medium                                                        |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Stack Sets for automated deployment                           |
| <b>Status</b>       | 4 Stack Set(s) defined                                        |

|                     |                                                               |
|---------------------|---------------------------------------------------------------|
| <b>WAFPillar</b>    | Security                                                      |
| <b>Question</b>     | How do you securely operate your workload                     |
| <b>BestPractice</b> | Stay up to date with security threats and recommendations     |
| <b>Severity</b>     | High                                                          |
| <b>Reference</b>    | <a href="https://aws.amazon.com/">https://aws.amazon.com/</a> |
| <b>Validation</b>   | Trusted Advisor checks                                        |
| <b>Status</b>       | Trusted Advisor accessible: 539 checks available              |